CLIENT SECURITY REVIEW / CONTROLLED DISTRIBUTION

SJC

Application Security Audit and Remediation Review

Singapore Journal of Cardiology | sjcjournal.com

Assessment date: 30 October 2026 | **Report:** SJC-SEC-2026-10-30 / v1.0

ASSESSMENT CONCLUSION

Confirmed source issues have been remediated and verified locally. Passive public checks show useful transport, cookie and response-header controls. Production deployment of the reviewed fixes and several operational controls still require evidence before final security sign-off.

275	8	0	4
PHP tests passed	JavaScript tests passed	Reported package advisories after updates	Public HTTPS endpoints sampled

This report covers five locally remediated security finding groups, three related reliability fixes, a control-by-control review, public HTTPS observations and prioritized follow-up actions. It distinguishes verified implementation from unverified production configuration.

REPORT CONTENTS

02 Scope and system boundaries

03 Findings and severity register

04 Dependency security remediation

05 Data integrity and packaging fixes

06 Identity and access controls

07 Content, files and API controls

08 Live HTTPS, headers and cookies

09 Privacy, mail and operations

10 Open risks and verification gaps

11 Executed verification and evidence

12 Related reliability fixes

13 Production closure plan

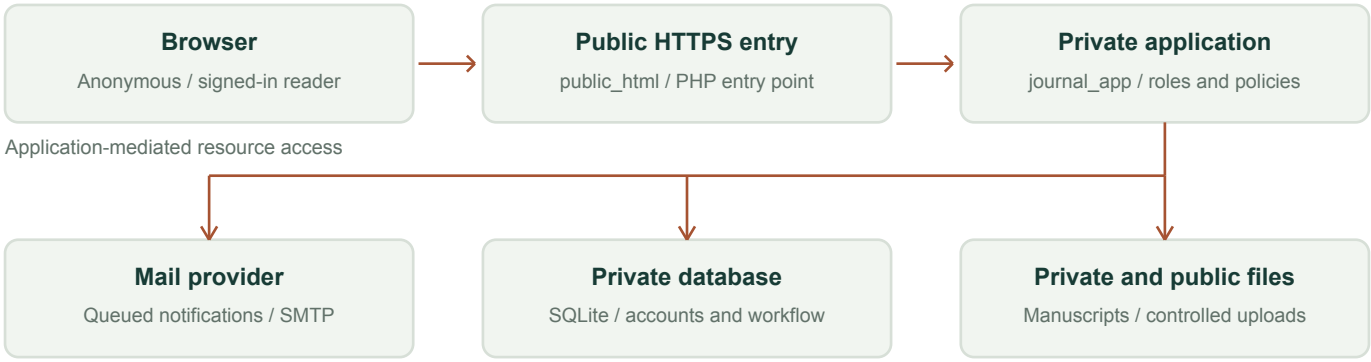
14 Evidence index and references

02 / SJC SECURITY ASSESSMENT

Scope and system boundaries

The reviewed application is a Laravel journal platform with public reading pages and protected administrator, editor, reviewer and author workflows. Its recorded Hostinger topology separates a public PHP document root from private application code, SQLite data and manuscripts.

Reviewed source packages: Laravel 13.34.0, Sanctum 4.3.3, Dompdf 3.1.6 and PDF.js 6.3.289, with Blade/Tailwind and a PHP 8.4.1+ requirement. These repository versions do not attest to installed live packages.



Area	Assessment boundary
Source and local fixes	Baseline f4b6367 plus the current uncommitted remediation set. Routes, middleware, policies, identity flows, editorial services, upload/storage behavior, browser scripts and dependency locks were sampled.
Executed local verification	Full PHP suite on isolated in-memory SQLite; targeted regressions; JavaScript tests; frontend build; changed-file formatting; dependency audits and Composer manifest validation.
Public live observations	Four unauthenticated HTTPS GET requests, one HTTP redirect request and one certificate-verified TLS negotiation for sjcjournal.com. No exploit payloads, login attempts or load tests.
Not assessed directly	Hostinger account settings, private environment values, production database contents, historical images, authenticated live roles/APIs, real mail delivery, WAF behavior, backup restoration and a full TLS scan.

Evidence labels used throughout

Locally verified: source change plus executed checks. **Source-supported:** reviewed code and relevant test coverage. **Observed live:** limited public response evidence. **Not verified:** needs additional operational access or testing.

The review used a Laravel specialist for application behavior and an independent security specialist for scoped review. Coverage is informed by OWASP ASVS control areas; it is not a requirement-by-requirement ASVS assessment, accreditation or regulatory compliance certification.

03 / SJC SECURITY ASSESSMENT

Findings and severity register

Severity reflects plausible impact and the demonstrated exposure context. Upstream package ratings are not automatically assigned to the whole production website. Findings below are fixed in the reviewed local source; their production presence/removal has not been verified.

ID / severity	Confirmed issue	Local status
SEC-01 / High	Symfony HTTP Foundation request-header parsing advisory; installed lock was 8.1.4.	Updated to 8.1.10; package audit clean.
SEC-02 / Medium	Symfony MIME parameter-name header-injection advisory; installed lock was 8.1.4.	Updated to 8.1.10. Application exploit path was not demonstrated.
SEC-03 / High (build)	Vite, shell-quote/concurrently and source-map-js advisories. Upstream ratings include critical/high.	Patched compatible versions; npm audit clean, including development dependencies.
SEC-04 / High potential	Private runtime/recovery material could be included by Docker COPY . . because exclusions were incomplete.	Exclusions corrected. No breach, historical image inspection or new Docker build established.
SEC-05 / Medium	Autosave could overwrite a newer same-second draft or act on stale manuscript state; restored form input could acquire a newer token.	Transactional fresh-state checks and version tokens; restored tokens preserved; regressions pass.

Related reliability corrections

ID	Behavior corrected
REL-01	Article slugs stay stable when titles change, preserving open form endpoints and established links.
REL-02	Retained workflow-file links for archived manuscripts return controlled 404 responses instead of null-parent 500 errors.
REL-03	Public-header menu handlers no longer interfere with the account menu in protected portals.

WHAT REMAINS OPEN

CSP inline allowances remain a verified hardening limitation. Manual-save concurrency retains its existing contract. Release deployment, privileged-account controls, malware handling, privacy retention and restoration procedures need the actions and evidence on pages 10 and 13.

High denotes potentially material confidentiality/availability impact. Medium denotes a material integrity or conditional security risk. Reliability fixes are recorded separately to avoid inflating the vulnerability count. No numerical security score or CVSS score was invented for application-specific findings.

04 / SJC SECURITY ASSESSMENT

Dependency security remediation

SEC-01 / HTTP request-header parsing

HIGH / LOCALLY REMEDIATED

The locked Symfony HTTP Foundation 8.1.4 package fell within CVE-2026-108082. The upstream advisory describes excessive regular-expression processing reachable through request-header parsing. This makes it a server-runtime availability concern; no attack was sent to the live website.

The lock now selects **8.1.10**, including the upstream correction and subsequent parsing-regression fixes. The updated dependency set passed the complete local PHP suite. The live installed version is not inferred from response headers.

SEC-02 / MIME parameter handling

MEDIUM / LOCALLY REMEDIATED

The locked Symfony MIME 8.1.4 package fell within CVE-2026-45070. The upstream issue concerns untrusted MIME parameter names being emitted into structured headers. The package was updated to **8.1.10**. A reachable application path supplying attacker-controlled parameter names was not demonstrated in this review.

SEC-03 / Development and build dependencies

UPSTREAM CRITICAL/HIGH RATINGS / CONTEXTUAL BUILD EXPOSURE

The npm audit reported advisories in development tooling. These matter to developer/build environments; they are not evidence that the production PHP website was remotely compromised. Targeted compatible updates were applied and the frontend build was rechecked.

Package	Before	Reviewed after
vite	8.2.2	8.2.4
concurrently	10.0.5	10.0.6
shell-quote	1.9.0	1.12.0 (through concurrently)
source-map-js	1.2.1	1.2.2

Audit result: Composer reported zero advisories and zero abandoned packages; npm reported zero vulnerabilities, including development dependencies. These are point-in-time registry checks, not proof that all code or dependencies are vulnerability-free.

Evidence: composer.lock; package.json; package-lock.json; executed Composer/npm audits. Primary Symfony advisories: R1 and R2 on page 14. The shell-quote advisory chain is one underlying issue, not two independent critical application vulnerabilities.

05 / SJC SECURITY ASSESSMENT

Integrity and packaging fixes

SEC-04 / Private files in build context

HIGH POTENTIAL CONFIDENTIALITY IMPACT / LOCALLY REMEDIATED

The earlier Docker exclusions covered selected storage subfolders but allowed other runtime/release material and the .codex recovery directory into the build context. The Dockerfile copies the context into application images. Such material could be embedded in an image if one were built from that working directory.

The updated .dockerignore excludes **.codex**, **output**, **tmp** and **storage/app/****, preserving only the intended .gitignore placeholder. This was independently checked against the relevant path patterns. Private file contents were not opened or reproduced in this report.

Closure needed: rebuild through the approved pipeline, inspect the resulting image/context and review any previously distributed image. Rotate credentials only where an actual or credible exposure is identified. New exclusions do not remove historical images or revoke credentials.

SEC-05 / Autosave concurrency and fresh-state checks

MEDIUM / LOCALLY REMEDIATED AND REGRESSION-TESTED

The original timestamp-only check could accept stale edits within the same second. Checks on a route-bound model could also become stale before the write. Separately, redisplayed validation input could be paired with a newer database token, allowing old text to overwrite a more recent draft.

Protection added	Verified behavior
Fresh transaction state	Refetch and lock the article, reauthorize current ownership/permissions and check its current editorial stage before writing.
Persisted draft-version token	Compare a SHA-256 hash of sorted persisted attributes; reject missing/stale versions with a controlled conflict response.
Browser token handling	Send the hidden draft_version, adopt the returned token only on success, and stop further autosaves after a conflict.
Validation redisplay	Retain submitted old version/timestamp values. Missing, malformed or array tokens are not upgraded to the current database version.

CONCURRENCY BOUNDARY
These checks protect autosave. Manual Save draft and other edit paths retain their separate pre-existing contracts; the report does not claim universal optimistic concurrency protection.

Evidence: Author/AutosaveController.php; Article::draftVersion(); author/articles/_form.blade.php; resources/js/portal.js; AuthorWorkflowTest; portal-autosave.test.mjs.

06 / SJC SECURITY ASSESSMENT

Identity and access controls

These controls are supported by current source and local tests. Actual production accounts, provider configuration and role assignments were not inspected.

Control	Reviewed implementation and evidence	Boundary / follow-up
Registration and passwords	Server-owned registration routes determine requested roles. Applicants remain pending, inactive and roleless until approval. Password hashing/composition and compromised-password checking are implemented. AuthenticationTest; RolePortalAuthenticationTest.	Public registration uses a minimum of nine characters with composition checks; do not describe a universal 12-character requirement. Application MFA was not demonstrated.
Verification and approval	Signed/throttled verification links are separate from Super Admin approval. Verification alone does not grant protected access. RegistrationVerificationTest tests approval/verification order and link tampering/expiry.	Production mail delivery, approval records and staff onboarding procedures require operator evidence.
Google identity	Verifier checks signature/algorithm, audience, issuer, expiry, verified email and subject; controller/tests cover state/nonce and linking/workspace boundaries.	Actual credentials, redirect URIs, provider-side MFA and production provider availability were not checked.
Roles and records	Protected portals require authentication, active/verified state and roles. Policies constrain ownership, assigned editor/reviewer access and permissions. AuthorizationBoundaryTest; PortalSecurityTest; ManuscriptWorkflowTest.	Representative source and regression coverage do not prove every possible mutation safe. Review live privileged accounts and role assignments.
Sessions and revocation	Login regenerates the session; logout invalidates it. Password changes/resets revoke tokens and older sessions. AuthenticateSession detects stale password hashes. CredentialRevocationTest.	Cookie flags were passively observed, but session encryption, storage retention and production revocation behavior remain configuration/operational checks.
API token boundaries	Sanctum token issuance requires active verified accounts; author writes require token abilities plus roles/policies. Public API publication boundaries and read-only-token rejection are tested.	No authenticated production API request was performed. Token-expiry configuration and credential governance must be confirmed privately.

REVIEWER POLICY MISMATCH

SECURITY.md describes reviewers as invitation-only. Current routes and tests permit public reviewer applications that remain pending, inactive and roleless. The owner should align policy and implementation. This mismatch is not evidence of direct privilege escalation.

Evidence: routes/auth.php; routes/portal.php; routes/api.php; ArticlePolicy; RegisteredUserController; GoogleIdTokenVerifier; CredentialRevocation; auth and authorization tests. See E2-E4 on page 14.

07 / SJC SECURITY ASSESSMENT

Content, files and API controls

Area	Source-supported control	Evidence limit
CSRF	Laravel web middleware and CSRF fields protect browser forms. Stateful Sanctum includes ValidateCsrfToken; autosave sends X-CSRF-TOKEN.	Framework feature tests normally bypass CSRF middleware. Passing tests are not a production CSRF penetration test.
Rich content and XSS	Blade escapes ordinary output. RichTextSanitizer restricts elements/attributes, URL schemes and iframe hosts; removes active elements and event handlers. Tests cover unsafe editorial markup and embeds.	Maintain the required DOM extension. No exhaustive browser XSS assessment occurred. CSP inline allowances remain a separate weakness in defense in depth.
Images and SVG	Image validation applies five-MB input limits and a 40-megapixel bound. SVG allowlisting rejects active elements, entities, processing instructions and external references. Optional lossless processing has deadlines.	Validation is not a malware scanner. Production extensions, binary availability and hosting resource/upload limits were not inspected.
Manuscript documents	Reviewed workflows explicitly use private local storage for manuscripts/reviews and public storage for public images. MIME, extension, size and purpose checks apply.	No antivirus or quarantine pipeline was observed. Accepted PDF/Office files are not proven malware-free by type validation.
Protected downloads	Controllers resolve recorded storage paths and enforce owner, staff or eligible reviewer access and permitted file purposes. Archived null-parent links now return 404.	Actual server permissions, public/private mapping and existing stored objects were not inspected. Keep private documents outside the public root.
Database and search	Sampled Eloquent/query-builder paths use bound parameters and validated filters. Author API writes combine token abilities, state and record policies.	No blanket claim that SQL injection is impossible. PostgreSQL-specific feature behavior and live authenticated API/CORS behavior were not exercised.
Abuse and dev bypasses	Source declares login/API/contact and selected mutation limits. Local bypasses require opt-in local/loopback conditions and use request-scoped temporary identities.	Real effectiveness depends on cache, proxy and deployment settings. Verify trusted proxies and that all local bypass flags are disabled in production.

Evidence: RichTextSanitizerTest; ImageUploadOptimizationTest; UploadManagementTest; ApiSecurityTest; AuthorizationBoundaryTest; FailureRecoveryTest; ErrorPopupTest; config/filesystems.php; relevant request classes and policies.

08 / SJC SECURITY ASSESSMENT

Live HTTPS, headers and cookies

The following observations were collected on 30 October 2026 from sjcjournal.com without signing in. Only public GET requests and one normal TLS negotiation were used. Session-cookie values and page tokens were not retained in this report.

Request / check	Observed result
HTTPS /	200; real journal homepage returned.
HTTPS /up	200; application health page returned.
HTTPS /admin/login	200; administrator sign-in page returned; X-Robots-Tag: noindex, nofollow.
HTTPS /robots.txt	200; text/plain response.
HTTP /	301 redirect to https://sjcjournal.com/.
Certificate and TLS	Hostname/certificate verification succeeded. One negotiation selected TLSv1.3 / TLS_AES_256_GCM_SHA384.
Certificate validity (UTC)	7 October 2026 06:19:36 through 5 January 2027 06:19:35.

Observed header	Value / interpretation
Strict-Transport-Security	max-age=31536000; includeSubDomains
X-Content-Type-Options / X-Frame-Options	nosniff / SAMEORIGIN
Referrer-Policy	strict-origin-when-cross-origin
Permissions-Policy	camera=(), microphone=(), geolocation=()
Cross-Origin-Opener-Policy	same-origin in the sampled responses
Content-Security-Policy	Present; self-based defaults, object-src none and base-uri/form-action self. script-src and style-src permit unsafe-inline. Homepage also allows configured analytics destinations.

Cookie interpretation

The observed session cookie had **Secure**, **HttpOnly** and **SameSite=Lax**. The XSRF-TOKEN cookie had Secure and SameSite=Lax without HttpOnly, consistent with a browser-readable CSRF-token cookie; that difference is not an authentication-cookie defect.

These samples do not identify installed PHP/package versions, prove all TLS versions/ciphers safe, establish WAF effectiveness or verify authenticated response caching. CSP hardening is listed as H1 on page 10.

09 / SJC SECURITY ASSESSMENT

Privacy, mail and operations

Area	Evidence-supported behavior	Operator responsibility
Third-party analytics	Public tracking is restricted by environment/host/request eligibility. Browser code loads analytics only after acceptance; tests cover saved denial, expiry, withdrawal and removing query data from tracked locations/downloads.	Verify actual privacy choices and enabled providers on production. Header allowlists alone do not prove that an analytics tag was loaded or a tracking event was sent.
First-party activity data	Article views can record account/session IDs, HMAC IP identifiers, referrers and user-agent data. Search/activity records are separate from optional third-party tags.	Define purposes, access and retention. Hashed identifiers can remain linkable. Third-party consent controls must not be described as covering all first-party logging.
Audit records	AuditService records actors, changes, raw request IP, user agent and request IDs. It removes top-level password, remember_token and token fields from recorded change arrays.	Review nested/provider-specific payloads before logging secrets. Establish authorized access, retention, deletion and monitoring; no complete historical-log secret scan occurred.
Editorial notifications	Workflow messages are queued after commit and author-facing notices omit confidential review text. Regression tests cover notification delivery behavior and retry rules.	No real email was sent. Verify SMTP configuration, DNS authentication, queue health and actual inbox delivery with an approved operational test.
Cron and queue worker	Source uses bounded selected-queue processing, an overlap lock and pause marker. Permanent SMTP rejections are handled without automatic repeated delivery. Scheduled publication/reminders and token pruning are declared.	Confirm both live cron jobs and their recent output. Review failed/held jobs deliberately; do not bulk retry or prune without assessing recipients and purpose.
Backups and incidents	Project guidance separates code rollback from database/uploads/configuration recovery and calls for protected backups.	Account MFA, encryption, off-host copies, retention, tested restores, alerting, incident contacts and recovery objectives need current operator evidence.

PRIVACY AND ASSURANCE BOUNDARY

This is a technical security assessment. It does not establish a legal basis for processing, compliance with a particular regulation, successful backup restoration or absence of sensitive data in historical logs/images.

Evidence: AnalyticsService; public-analytics.js and its tests; Public/ArticleController::recordView; AuditService; WorkflowNotification; hostinger-mail-worker.php; MailQueueReliabilityTest; routes/console.php.

10 / SJC SECURITY ASSESSMENT

Open risks and verification gaps

The entries below remain open or require explicit operational evidence. They are not all confirmed exploitable vulnerabilities. Priority determines the order of closure; it is separate from an upstream CVSS rating.

ID / priority	Observation	Recommended action / owner
G1 / P1	Local fixes and patched dependencies have not been proven installed on the live website. Response headers cannot establish their versions.	Release owner: identify the production release, deploy the coordinated fix set and record installed package versions plus acceptance results.
G2 / P1	Private runtime files could have entered historical Docker contexts/images. No historical artifact inspection occurred.	Build/hosting owner: rebuild and inspect the new image; review previously distributed images and assess credential rotation if exposure is found.
H1 / P2	CSP permits unsafe-inline scripts and styles, also observed live. This weakens defense in depth; exploitable XSS was not demonstrated.	Developer: inventory inline scripts/styles, implement nonce/hash-based script authorization, test in report-only mode, then enforce a compatible policy.
H2 / P2	Manual draft updates do not compare the new autosave token, although current workflow state is locked/checked.	Developer/product owner: define simultaneous manual-edit behavior and consider extending conflict protection. Do not claim every edit path is protected.
H3 / P2	Actual proxy/cache configuration and privileged-account MFA were not verified. Example proxy settings trust all.	Hosting/security owner: confirm the upstream trust boundary, source-IP integrity, rate-limit cache and MFA/account-review requirements.
H4 / P2	Document scanning/quarantine, restoration evidence, incident alerting and data retention are not demonstrated.	Operations/data owner: document risk decisions, scanning needs, restore tests, retention/access controls and monitoring responsibilities.
D1 / P3	Reviewer invitation-only policy text conflicts with public pending reviewer applications. Access still requires approval.	Journal owner: choose the intended policy, align documentation and routes, and retain regression coverage for the chosen behavior.

NO NUMERICAL GUARANTEE

A passing test suite and zero reported package advisories do not make a website risk-free. The report makes no claim that the production site has completed an authenticated penetration test, exhaustive source audit or full ASVS verification.

11 / SJC SECURITY ASSESSMENT

Executed verification and evidence

Check	Recorded outcome	Boundary
PHPUnit full suite	275 passed; 3,089 assertions; zero failures, errors or skips.	Isolated PHP 8.4.12, in-memory SQLite; current remediated source.
JavaScript suite	8 passed: account menus, autosave success/conflict token handling and analytics consent.	Node 24.20.0; actual scripts exercised by controlled test harnesses, not a browser visual audit.
Frontend build	Vite 8.2.4 production asset build passed.	Does not certify a production Docker image or live asset deployment.
Formatting and manifests	Pint passed for the changed PHP files; Composer validate --strict passed.	Changed-file formatting, not a claim that every historical file was reformatted.
Dependency registries	Composer: zero advisories/abandoned packages. npm: zero reported vulnerabilities, including dev dependencies.	Point-in-time package records for the reviewed lockfiles.
Regression evidence	Four selected new checks failed against their original implementations with expected buggy results, then passed after fixes.	Article slug stability, archived-file 500, missing-token autosave and stale route-bound state.

PHP suite composition

Test group	Cases
Core unit tests	14
Other feature/integration tests	135
Identity/account feature tests	70
Portal/workflow feature tests	56

The total includes functional and security regressions; it is not a count of 275 distinct security controls or vulnerabilities. Baseline verification had one PNG-compression failure because the native runtime lacked the optional utility installed by Docker. After supplying OptiPNG privately, the complete final suite passed.

ISOLATION AND LIMITATIONS

Tests used a disposable copy, an in-memory database and non-delivering mail settings. Existing journal data and running services were not used for tests. Docker/PostgreSQL integration, authenticated live roles/APIs, real mail and browser visual verification were not run.

Evidence: Final JUnit result: final-junit.xml; final-phpunit.log retained in the local audit evidence cache. No raw session cookies, credentials, personal record exports or private manuscript data are included.

12 / SJC SECURITY ASSESSMENT

Related reliability corrections

REL-01 / Stable article links after title edits

LOW AVAILABILITY / LOCALLY VERIFIED

Article route binding uses a slug. Regenerating that slug when the title changes invalidated already-rendered form/autosave URLs; manual redirects could also use an obsolete route value. Established article slugs now remain stable when the title changes.

Creation and uniqueness checks remain in place, and other slugged entities retain their existing rename behavior. Model tests cover draft/published title edits; author workflow tests cover repeated title autosaves and a resolvable manual-save redirect.

Evidence: app/Models/Article.php; app/Models/Concerns/HasUniqueSlug.php; ArticleModelTest; AuthorWorkflowTest.

REL-02 / Archived-file links return controlled errors

LOW AVAILABILITY / LOCALLY VERIFIED

A retained workflow-file row could reference a soft-deleted article. Its active relation resolved to null and was passed to a method requiring an Article, producing a 500 error. The controller now returns 404 before evaluating typed access checks.

Regression tests cover the author and reviewer download aliases while confirming the private file and database row remain intact. This change does not grant new archive access or delete preserved files.

Evidence: app/Http/Controllers/WorkflowController.php:73; ArchivedEditorialRecordTest.

REL-03 / Portal account-menu interference

LOW USABILITY / LOCALLY VERIFIED

The public JavaScript bundle also runs in portal layouts. Its global menu selectors could attach competing handlers to the portal account toggle, immediately reversing the open state. Public menu controls are now scoped to the public site header.

JavaScript regressions execute the portal script with the shared public bundle and verify open/close/Escape behavior. A separate test keeps the public account menu and outside-click behavior working.

Evidence: resources/js/app.js; resources/js/portal.js; tests/JavaScript/account-menu.test.mjs.

CLASSIFICATION
These issues are reported for complete change traceability. They are not counted as additional critical/high security vulnerabilities, and their local verification does not establish deployment on sjcjournal.com.

13 / SJC SECURITY ASSESSMENT

Production security closure plan

Use the following as a reviewable release checklist. No production deployment or account changes were performed while preparing this report. Acceptance requires actual evidence, not only a completed checkbox.

Order / owner	Required evidence before closure
1. Release owner	Identify the exact reviewed source/fix set, lockfiles, target environment and planned release. Record the scope and responsible approver before any deployment.
2. Data/hosting owner	Take a consistent database snapshot and matching upload/configuration backup; validate a restore copy and retain a rollback plan. Preserve the existing APP_KEY and active database path.
3. Build owner	Build with corrected exclusions. Inspect the produced image/context for private runtime and recovery artifacts; decide how to handle older images.
4. Application maintainer	Deploy the coordinated form, portal.js, autosave controller and model changes on staging. Install reviewed dependencies, publish matching assets and refresh caches; record versions and audits.
5. Security/QA owner	On controlled staging, verify CSRF enforcement, unauthenticated access denial, cross-role/cross-record boundaries, missing/stale autosave tokens and validation-redisplay conflicts.
6. Hosting owner	Privately confirm production environment/debug settings, secure session configuration, trusted proxies, local bypass flags, storage mapping/permissions and PHP security patch level.
7. Journal administrator	Review privileged accounts, staff approval and reviewer policy. Confirm appropriate infrastructure/identity-provider MFA and administrative recovery access.
8. Operations owner	Inspect both cron jobs and queue output; perform one approved real delivery test; preserve held historical jobs and confidential editorial content.
9. Data/operations owner	Approve retention/access rules, off-host encrypted backups, a documented restore test, failed-job/log review and incident contacts/alerts.
10. Release approver	After the preceding gates, refresh the rollback backup and deploy the coordinated production release. Reload old edit forms, record installed versions, repeat live HTTPS/workflow checks and document acceptance or rollback.

COMPLETION CRITERION

Close a finding only when the intended change is present in the release being assessed and the relevant verification evidence is recorded. Mark unresolved production controls as pending or formally accepted with an owner and review date.

14 / SJC SECURITY ASSESSMENT

Evidence index and references

Paths below are relative to the supplied project source. The report is based on baseline **f4b6367** plus the reviewed local fixes, not on an assumed production revision.

ID	Primary project evidence
E1	composer.json / composer.lock; package.json / package-lock.json; current dependency audit and frontend build outputs.
E2	routes/auth.php; routes/portal.php; routes/api.php; authentication controllers/requests; GoogleIdTokenVerifier; ArticlePolicy and MediaPolicy.
E3	CredentialRevocation; AuthenticateSession middleware configuration; config/session.php; config/sanctum.php; auth/revocation tests.
E4	Author/AutosaveController.php; Article::draftVersion(); author/articles/_form.blade.php; portal.js; AuthorWorkflowTest; portal-autosave.test.mjs.
E5	RichTextSanitizer; ImageUploadOptimizer; MediaStorageService; filesystem configuration; WorkflowController; upload/API/authorization tests.
E6	SecurityHeaders middleware; config/security.php; bootstrap/app.php; FailureRecoveryTest; ErrorPopupTest; passive public HTTP/TLS observations.
E7	AnalyticsService; public-analytics.js; Public/ArticleController::recordView; AuditService; analytics tests; mail worker and notification/queue tests.
E8	.dockerignore; Dockerfile; SECURITY.md; README; docs/TECH_STACK.md; final local JUnit/formatting/validation results.

External primary references

R1 - Symfony HTTP Foundation advisory, CVE-2026-108082

R2 - Symfony MIME advisory, CVE-2026-45070

R3 - OWASP ASVS overview and scope

R4 - OWASP Content Security Policy guidance

R5 - Assessed public website

Reviewed change-set fingerprint

SHA-256 over the sorted changed source-file paths and contents, including the two new JavaScript regression files. This identifies the reviewed local fix set; it is not a deployed-release attestation.

```
a77f139d4ed278e0a35b0e54b50700b8ed8f02e681111a1b77f259de9b999b96
```

Prepared 30 October 2026. Package advisories, public certificates, configuration and installed releases can change after this date. Reassess affected controls after a release, infrastructure change or material new advisory. No credentials or private journal record contents are included.